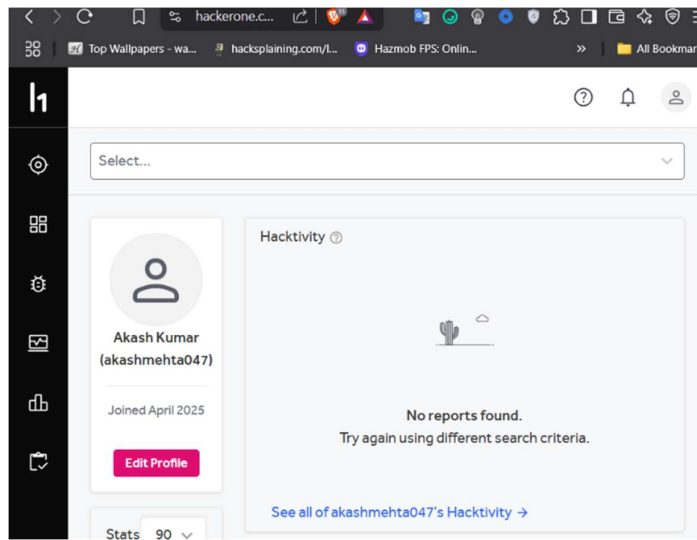
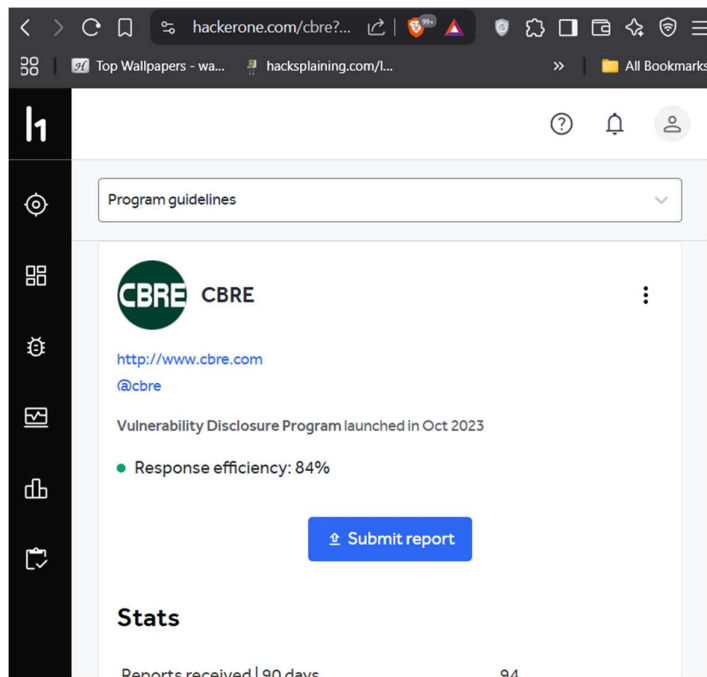


Introduction to Bug Bounty

1. Using HackerOne



2. Found a vulnerable website



3. Valuable vulnerability on this site

Valuable Vulnerabilities

- Remote Code Execution
- SQL Injection
- Privilege Escalation to Admin Level
- XML Injection
- Insecure Direct Object Reference
- Subdomain Takeovers

4. Out of scope Vulnerabilities

Out-of-Scope Vulnerabilities

The following vulnerabilities are considered out of scope for CBRE's Responsible Disclosure Program:

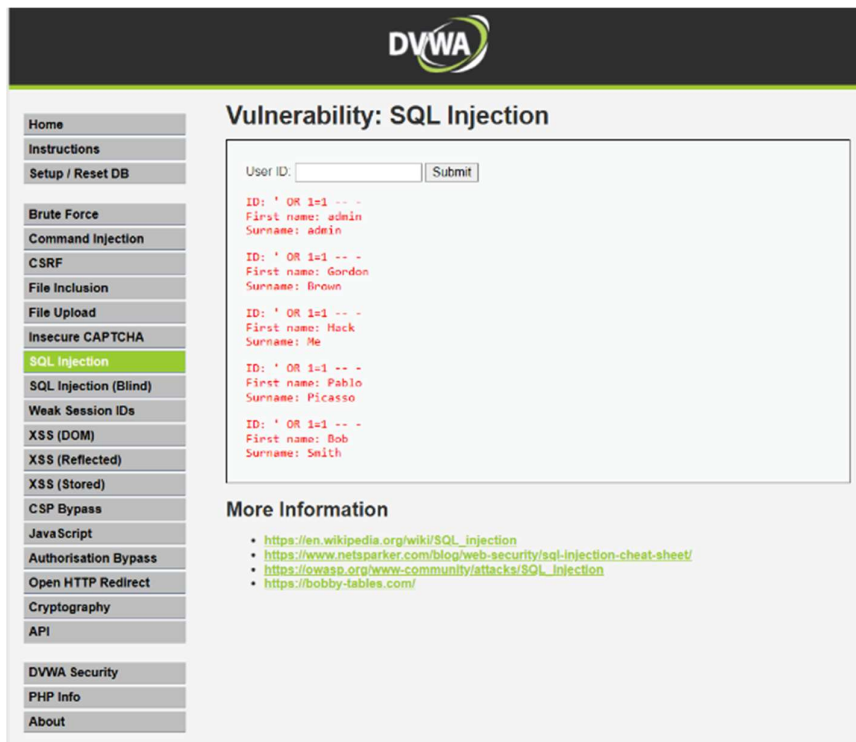
- Physical testing, including IOT and IIOT devices, BMS and HVAC environments
- Social engineering
- Phishing our employees or clients
- Denial of service attacks
- Resource exhaustion attacks
- Credential Exposures on Non-CBRE Owned Sites.

Website Info

CBRE earned its position as the world's leading commercial real estate services and investment firm by doing business according to the highest standards and living out our [values of Respect, Integrity, Service and Excellence](#). These values permeate all aspects of our business, including our efforts to protect the privacy and security of our employees, clients, investors, suppliers and others

SQL Injection Practice:

SQL Injection in a test environment



The screenshot shows the DVWA (Damn Vulnerable Web Application) interface. The top navigation bar includes links for Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection (highlighted), SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), CSP Bypass, JavaScript, Authorisation Bypass, Open HTTP Redirect, Cryptography, API, DVWA Security, PHP Info, and About.

Vulnerability: SQL Injection

User ID:

```
ID: ' OR 1=1 -- -
First name: admin
Surname: admin

ID: ' OR 1=1 -- -
First name: Gordon
Surname: Brown

ID: ' OR 1=1 -- -
First name: Hack
Surname: Me

ID: ' OR 1=1 -- -
First name: Pablo
Surname: Picasso

ID: ' OR 1=1 -- -
First name: Bob
Surname: Smith
```

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://owasp.org/www-community/attacks/SQL_injection
- <https://bobby-tables.com/>